Segurança de Dados

MCTA023-17

TLS - Transport Layer Security

Profª Denise Goya

Roteiro

- Brevemente: arquitetura TCP/IP
  - Para podermos falar em Segurança na Web, recomendado ter cursado a disciplina Redes de Computadores
- Framework TLS (antigo SSL/TLS)
- Juntando tudo o que vimos até agora:
  - Proteção de aplicações Web

Arquitetura de Redes

Arquitetura em camadas:

- para dividir a complexidade das muitas tarefas envolvidas num processo de comunicação em camadas (agrupando funcionalidades e responsabilidades)
- para viabilizar interoperabilidade entre diferentes tecnologias

exemplos:

- TCP/IP
- modelo de referência OSI

Arquitetura TCP/IP

Quatro camadas para pilha de protocolos:

- Aplicação
- Transporte
- Internet
- Interface com a Rede

mais próximo
do nível físico
(hardware)

Arquitetura TCP/IP

Exemplos de protocolos distribuídos nas camadas

Aplicação: HTTP
Transporte: TCP
Internet: IP
Enlace: ARP

Internet protocol suite

Application layer
DHCP · DHCPv6 · DNS · FTP · HTTP · IMAP · IRC · LDAP · MGCP · NNTP · BGP · NTP · POP · RPC · RTP · RTSP · RIP · SIP · SMTP · SNMP · SOCKS · SSH · Telnet · TLS/SSL · XMPP · (more)

Transport layer
TCP · UDP · DCCP · SCTP · RSVP · (more)

Internet layer
IP (IPv4 · IPv6) · ICMP · ICMPv6 · ECN · IGMP · IPsec · (more)

Link layer
ARP/InARP · NDP · OSPF · Tunnels (L2TP) · PPP · Media access control (Ethernet · DSL · ISDN · FDDI) · (more)

Arquitetura TCP/IP

- Aplicação:
  - serviço qualquer para o usuário
- Transporte:
  - serviço de entrega
- Internet:
  - endereçamento/ roteamento
- Enlace/camada física:
  - interface com o meio físico de comunic.

Internet protocol suite

Application layer

DHCP · DHCPv6 · DNS · FTP · HTTP · IMAP · IRC · LDAP · MGCP · NNTP · BGP · NTP · POP · RPC · RTP · RTSP · RIP · SIP · SMTP · SNMP · SOCKS · SSH · Telnet · TLS/SSL · XMPP · (more)

Transport layer

TCP · UDP · DCCP · SCTP · RSVP · (more)

Internet layer

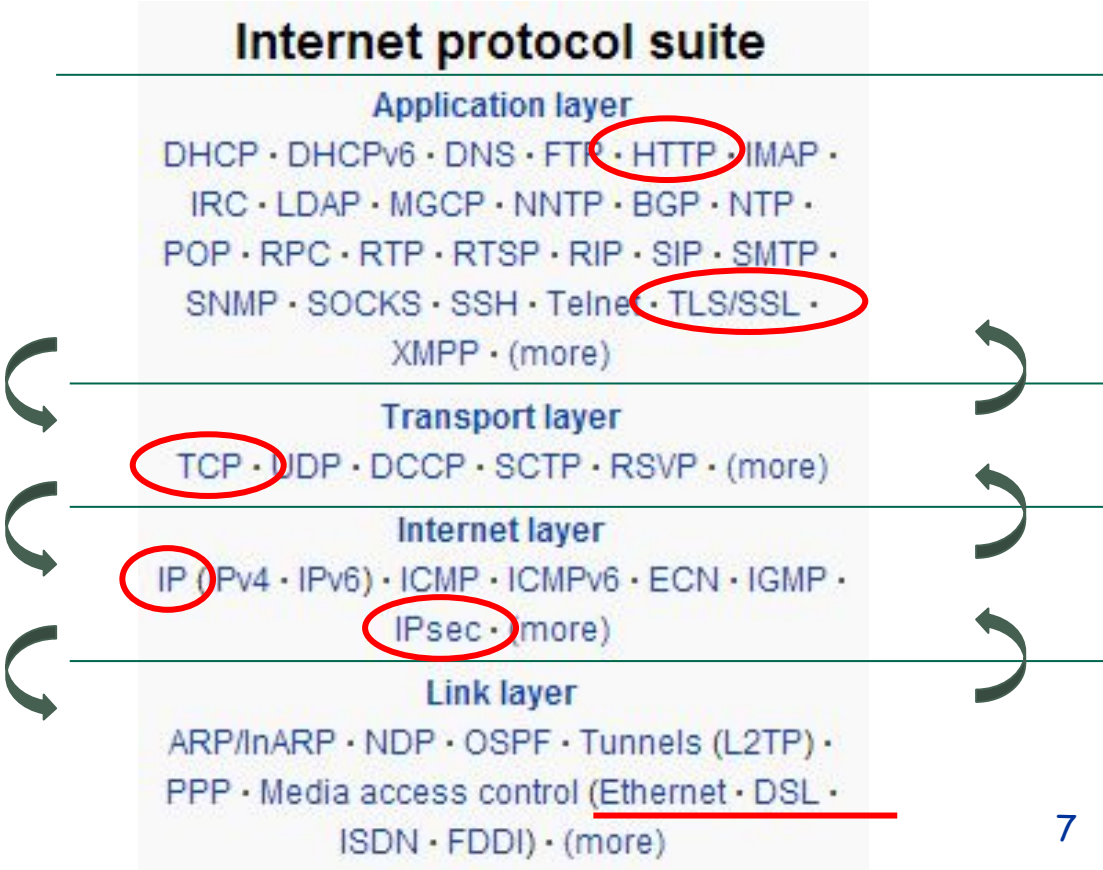
IP (IPv4 · IPv6) · ICMP · ICMPv6 · ECN · IGMP · IPsec · (more)

Link layer

ARP/InARP · NDP · OSPF · Tunnels (L2TP) · PPP · Media access control (Ethernet · DSL · ISDN · FDDI) · (more)

Arquitetura TCP/IP

Dado de uma camada é encapsulado e passado para a camada seguinte

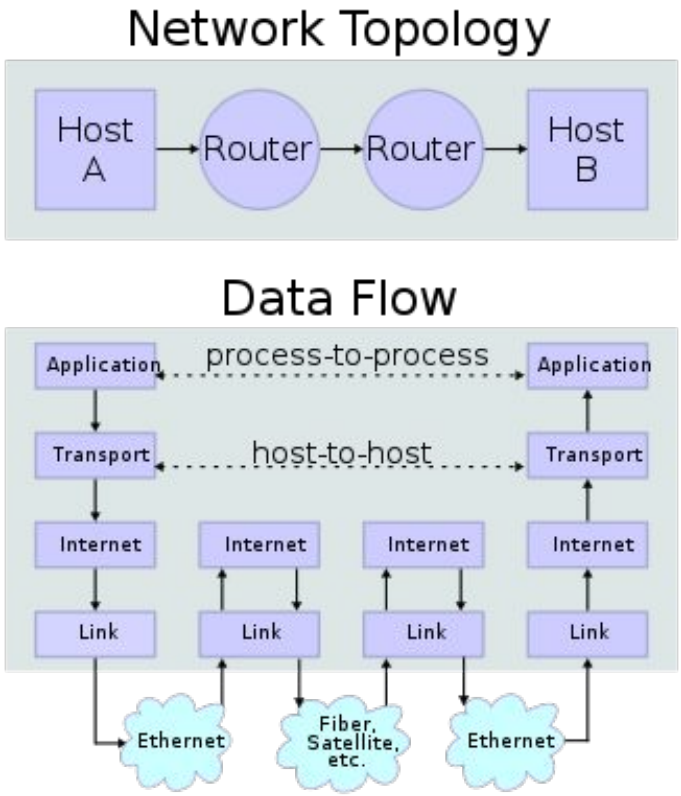


Arquitetura TCP/IP

Exemplo:

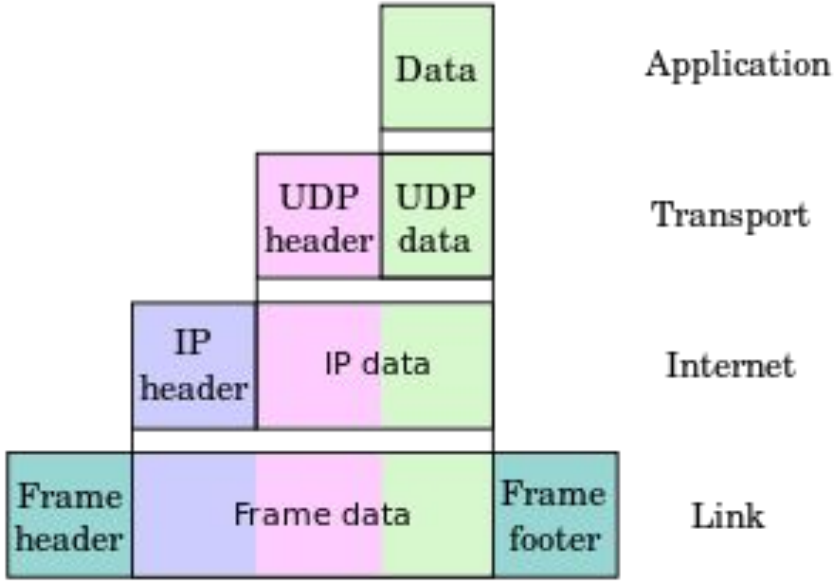
Comunicação entre dois equipamentos, com dois roteadores no meio do caminho

Fluxo dos dados entre os equipamentos



Arquitetura TCP/IP

Exemplo de encapsulamento



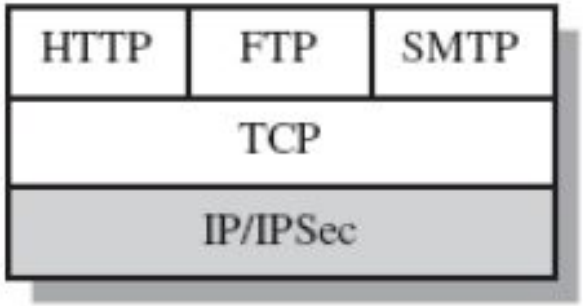
Ameaças de Segurança na Web

	Ameaças	Conseqüências	Contramedidas
Integridade	• Modificação de dados do usuário • Navegador cavalo-de-tróia • Modificação de memória • Modificação de mensagens em trânsito	• Perda de informações • Comprometimento da máquina • Vulnerabilidade a todas as outras ameaças Somas de verificação (checksums) criptográficas	Somas de verificação (checksums) criptográficas
Confidencialidade	• Registro não autorizado de tráfego na rede • Roubo de informações do servidor • Roubo de dados do cliente • Informações sobre configurações de rede • Informações sobre qual cliente fala com o servidor	• Perda de informações • Perda de privacidade	Criptografia, proxies Web
Negação de serviço	• Encerramento de threads do usuário • Inundação da máquina com solicitações falsas • Preenchimento da capacidade total do disco ou da memória • Isolamento da máquina por ataques de DNS	• Interrupção • Incômodo • Impede que o usuário realize o trabalho	Difícil de impedir
Autenticação	• Simulação de usuários legítimos • Falsificação de dados	• Falsificação da identidade do usuário • Crença de que informações falsas são válidas	Técnicas criptográficas

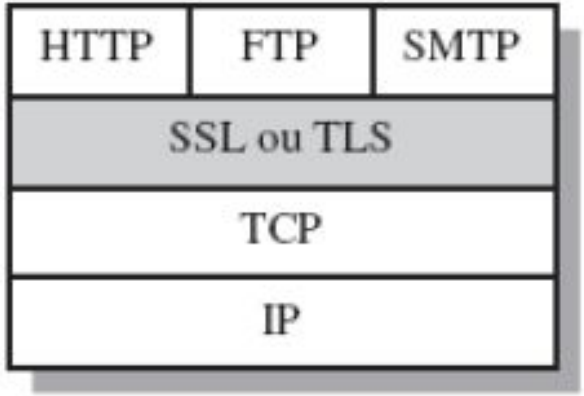
Proteção de Tráfego Web

Em diferentes níveis:

- de rede (camada Internet)
- de transporte
- de aplicação



(a) Nível de rede



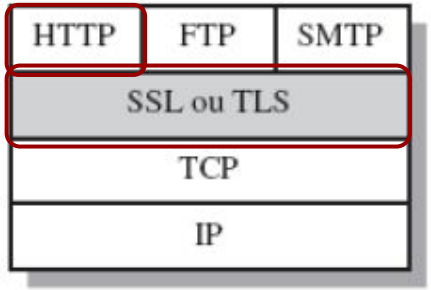
(b) Nível de transporte

HTTPS: Proteção no Nível Aplicação

HTTP: tráfego em claro e sem garantia de integridade

HTTPS: proteção via camada adicional de segurança TLS

- Conexão segura entre o servidor Web e o cliente navegador



(b) Nível de transporte

TLS

TLS: Transport Layer Security

- Substitui o SSL, Secure Socket Layer, cuja última versão v3.0 foi tornada obsoleta desde 2015

proteção no nível de **transporte**

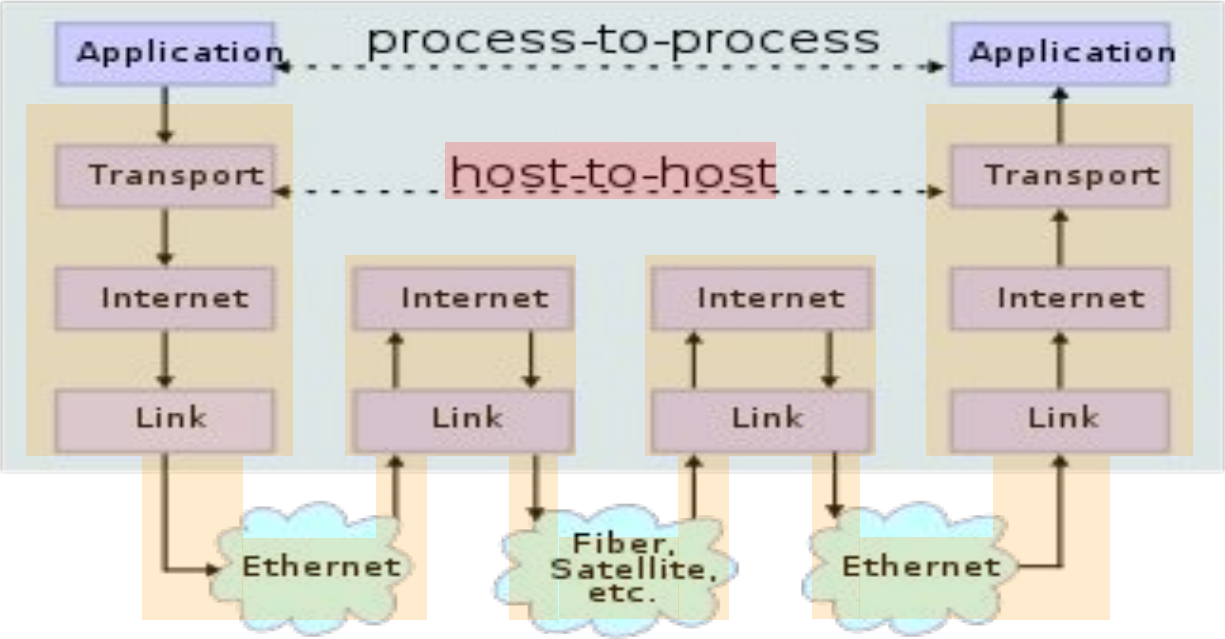
Arquitetura TLS

TLS não é um único protocolo, mas um conjunto de protocolos em duas camadas para:

- estabelecer conexão e transporte
  - camada de transporte
  - **conexão TLS** é um transporte par-a-par (de um host a outro)
  - toda conexão é associada a uma única sessão
- estabelecer sessão de comunicação
  - camada de aplicação TCP/IP (ou camada de sessão do modelo OSI em sete camadas)
  - **sessão TLS** é uma associação entre um cliente e um servidor: estabelecida pelo protocolo de **Handshake**

Arquitetura TLS

TLS faz uso do TCP para prover segurança **fim-a-fim** no nível de transporte



Arquitetura TLS

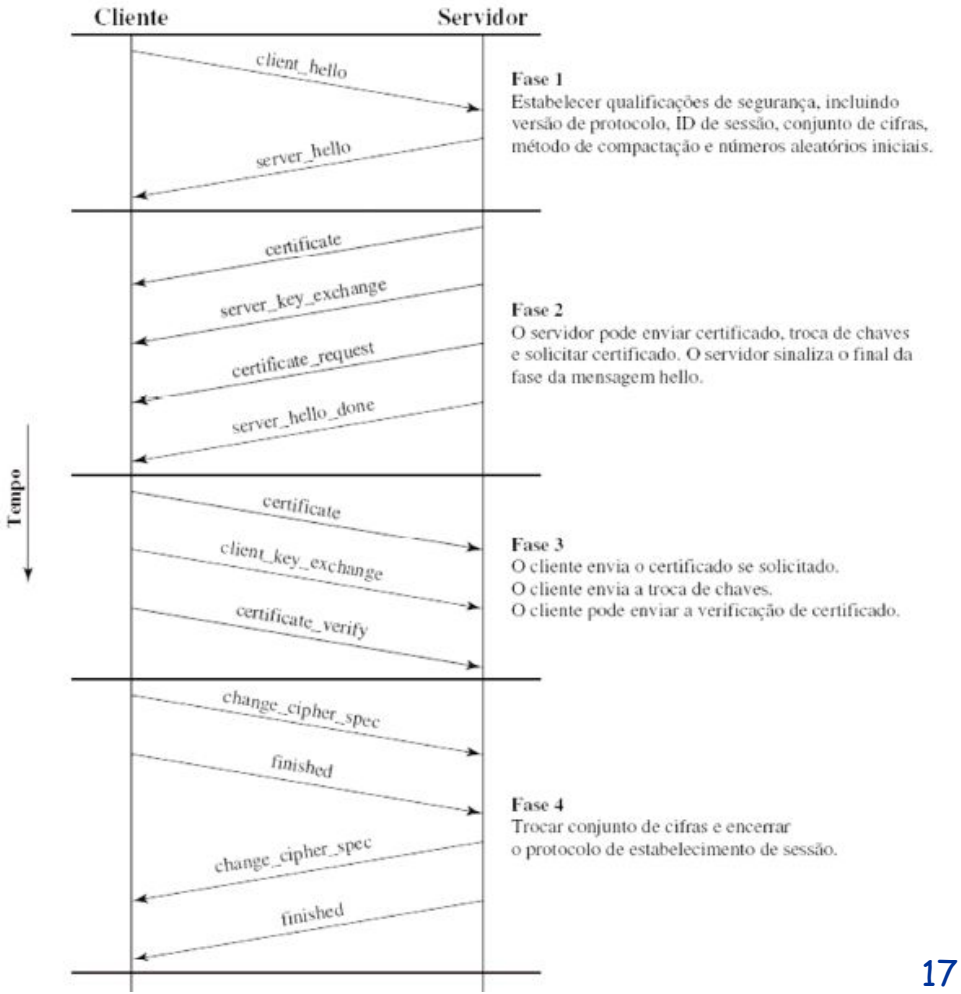
Pilha de protocolos TLS (baseada no antigo SSL):

- **TLS Handshake**: identificação e autenticação das partes envolvidas; acordo de chave secreta para a sessão; escolha de algoritmos para a sessão
  - Escolha de algoritmos: cliente e servidor entram em acordo sobre que algoritmos e tamanhos de chave usar (são selecionados os de maior segurança que ambos suportam)
  - Somente depois das etapas acima concluídas é que segue:
- **TLS Record** Protocol: serviços de sigilo e integridade das mensagens trafegadas na sessão

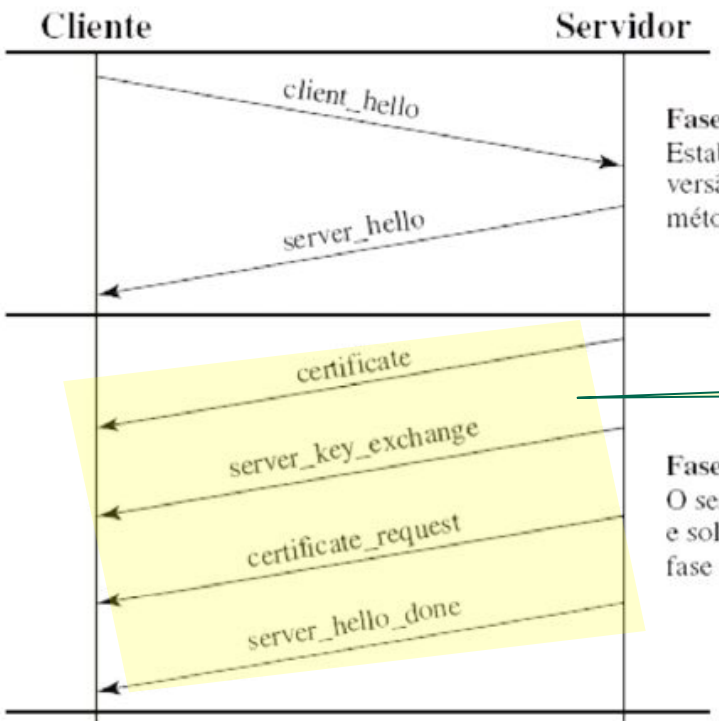
TLS Handshake

cliente e servidor trocam mensagens, em quatro fases

- início da comunicação
- acordo de chave secreta
- acordo sobre todos algoritmos e parâmetros



TLS Handshake: Fases 1 e 2

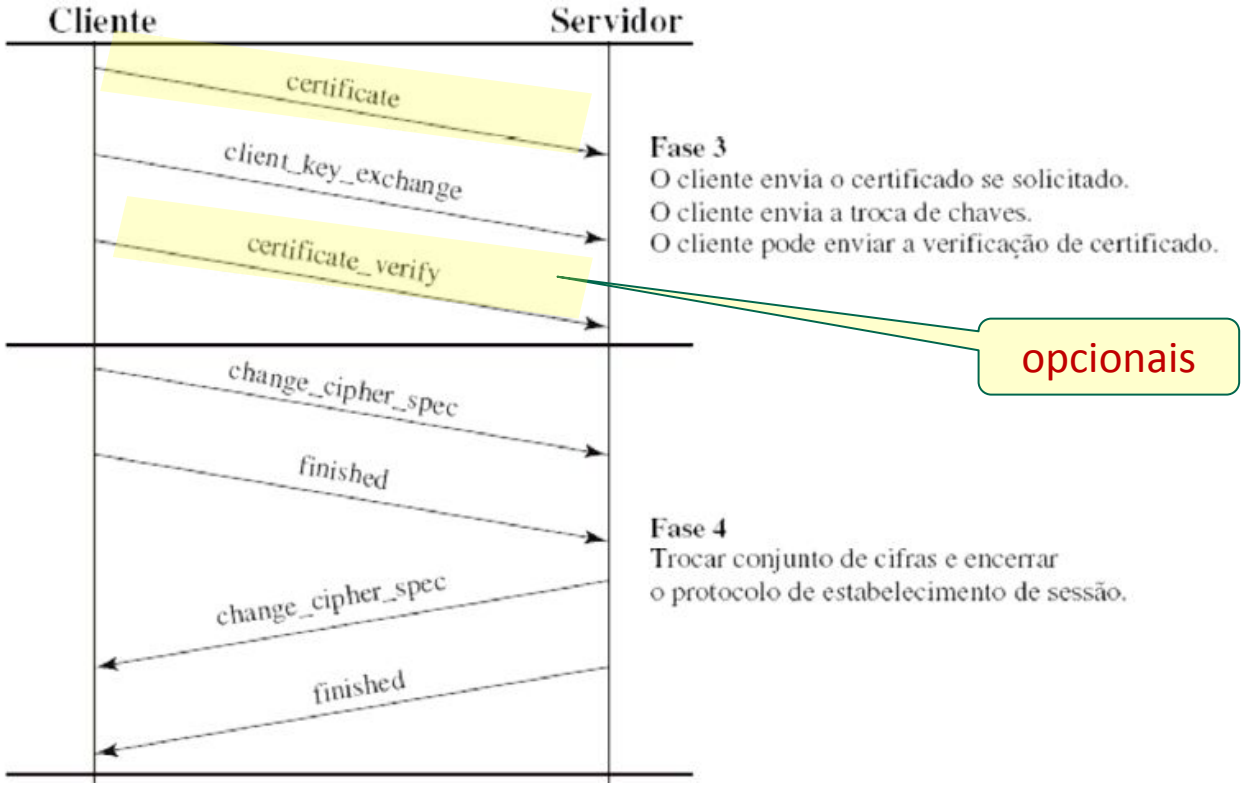


Fase 1
Estabelecer qualificações de segurança, incluindo versão de protocolo, ID de sessão, conjunto de cifras, método de compactação e números aleatórios iniciais.

opcional

Fase 2
O servidor pode enviar certificado, troca de chaves e solicitar certificado. O servidor sinaliza o final da fase da mensagem hello.

TLS Handshake: Fases 3 e 4



TLS: Acordo de Chave e Autenticação

TLS v.1.3 (RFC 8446):

- DHE-RSA: DiffieHellman efêmero com RSA
  - Efêmero (aleatório de uso único) confere segurança no futuro (mesmo que as sessões sejam gravadas hoje e a chave secreta venha a ser comprometida, sigilo da sessão é preservado)
  - RSA é usado para autenticar (assinar um certificado)
- ECDHE-RSA: DHE sobre curvas elípticas + RSA
- ECDHE-ECDSA: DHE sobre curvas elípticas + DSA

TLS v1.2 (padrão até ano de 2018) inclui algoritmos vulneráveis para acordo autenticado: tornados obsoletos

TLS: Algoritmos Suportados

TLS v.1.3:

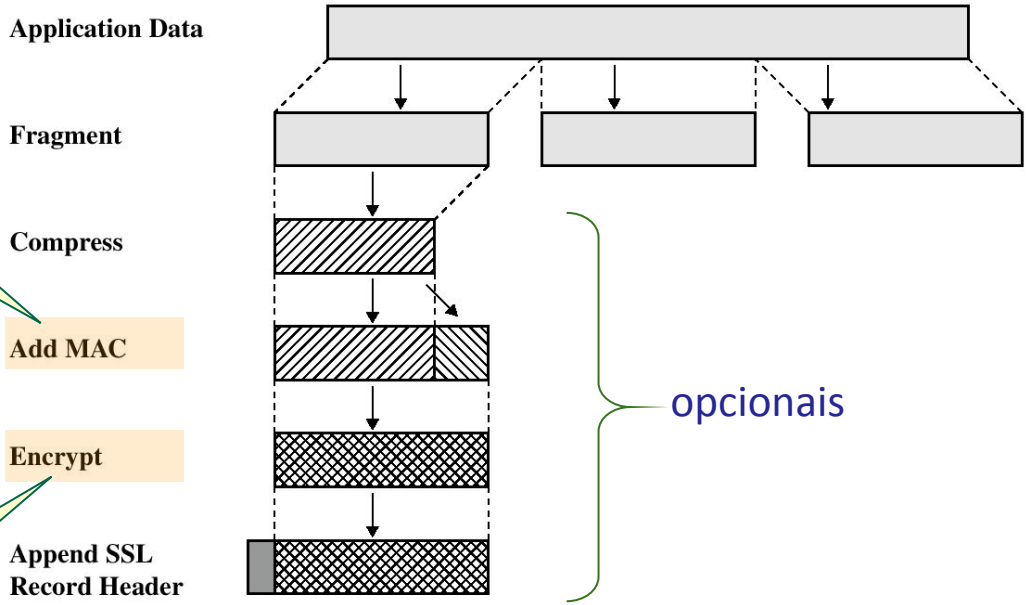
- Cifras de bloco:
  - AES, Camellia, Aria, Seed
  - Modos de operação: CBC, GCM
- Cifra de fluxo:
  - ChaCha20, com Poly1305 (MAC)
- Código de autenticação de mensagem:
  - HMAC-SHA256/384 (SHA-224 tornado obsoleto)
  - AEAD (Authenticated Encryption with Associated Data) é o recomendado

TLS Record Protocol

Integridade + Autenticidade de msg

usam chave secreta acordada no handshake

Confidencialidade



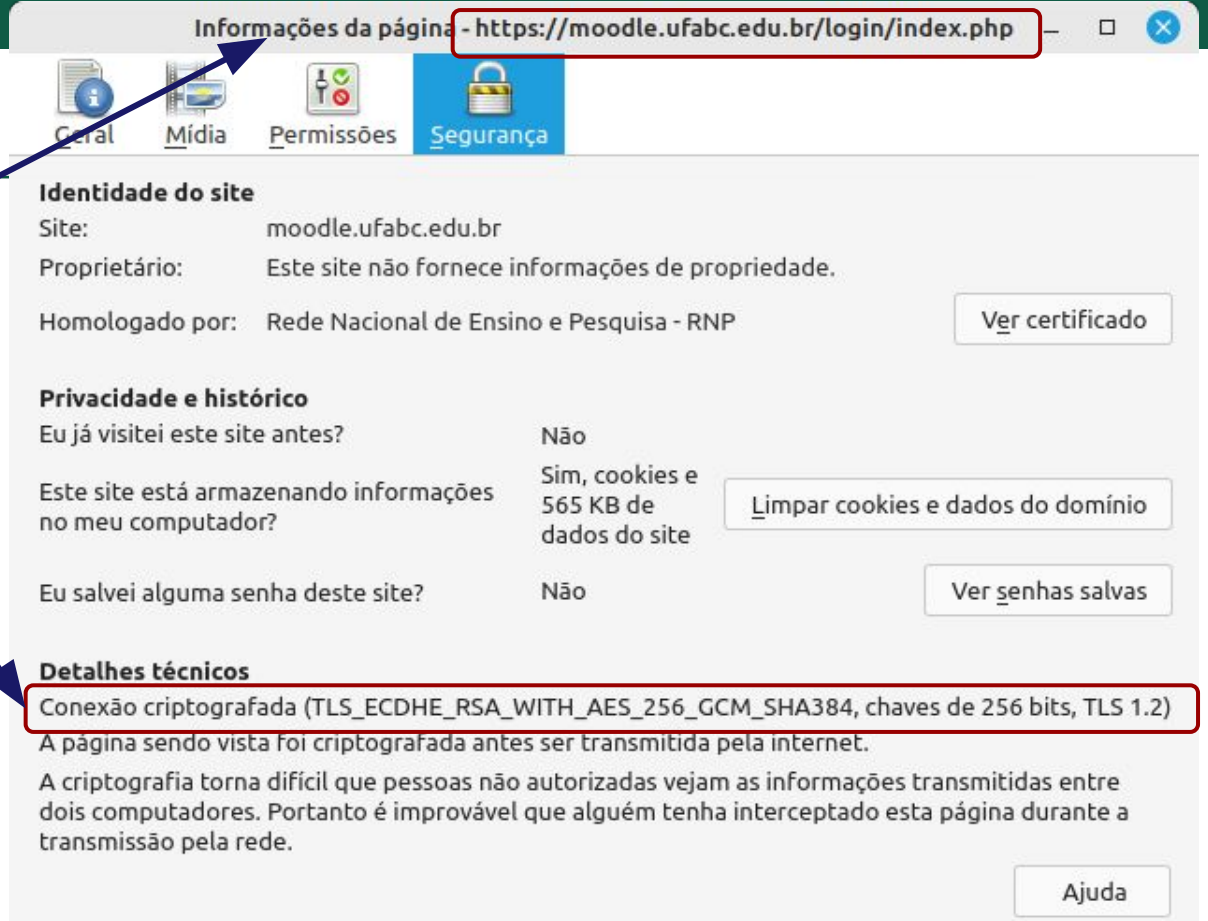
TLS: Exemplos de Aplicação

- HTTPS: HTTP sobre TLS
  - nível aplicação
  - em comércio eletrônico, operações bancárias, etc
  - são cifrados: URL, conteúdo do documento, dos formulários, dos cookies, conteúdo do header HTTP
- Segurança para outros tráfegos (SMTP, FTP...)
- OpenVPN (tunelamento de todo tráfego em uma rede privada virtual) e outras implementações de VPN
- Proteção de tráfego SIP (Session Initiation Protocol), como por exemplo VoIP

Aplicação

HTTPS
via TLS, com:

1. ECDHE_RSA:
   - DH sobre curva elíptica com forward secrecy, RSA
2. AES_256_GCM:
3. SHA:
   - Confirmação da chave acordada



Key exchange/agreement and authentication						
Algorithm	SSL 2.0	SSL 3.0	TLS 1.0	TLS 1.1	TLS 1.2	TLS 1.3
RSA	Yes	Yes	Yes	Yes	Yes	No
DH-RSA	No	Yes	Yes	Yes	Yes	No
DHE-RSA (forward secrecy)	No	Yes	Yes	Yes	Yes	Yes
ECDH-RSA	No	No	Yes	Yes	Yes	No
ECDHE-RSA (forward secrecy)	No	No	Yes	Yes	Yes	Yes
DH-DSS	No	Yes	Yes	Yes	Yes	No
DHE-DSS (forward secrecy)	No	Yes	Yes	Yes	Yes	No[79]
DHE-ECDSA (forward secrecy)	No	No	No	No	No	Yes
ECDH-ECDSA	No	No	Yes	Yes	Yes	No
ECDHE-ECDSA (forward secrecy)	No	No	Yes	Yes	Yes	Yes

Alguns algoritmos para o Handshake

Fonte: https://en.wikipedia.org/wiki/Transport_Layer_Security

Cipher security against publicly known feasible attacks

Cipher		Protocol version					
Algorithm	Nominal strength (bits)	SSL 2.0	SSL 3.0[n 1][n 2][n 3][n 4]	TLS 1.0[n 1][n 3]	TLS 1.1[n 1]	TLS 1.2[n 1]	TLS 1.3
AES GCM[82][n 5]	256, 128	—	—	—	—	Secure	Secure
AES CCM[83][n 5]		—	—	—	—	Secure	Secure
AES CBC[n 6]		—	Insecure	Depends on mitigations	Depends on mitigations	Depends on mitigations	—
Camellia GCM[84][n 5]	256, 128	—	—	—	—	Secure	—
Camellia CBC[85][n 6]		—	Insecure	Depends on mitigations	Depends on mitigations	Depends on mitigations	—

Alguns algoritmos para sigilo de sessão

Fonte: https://en.wikipedia.org/wiki/Transport_Layer_Security

Exemplos de Implementação TLS/SSL

- OpenSSL
  - opensource (licença BSD)
- GnuTLS
  - opensource (licença LGPL)
- JSSE
  - Java Secure Socket Extension
  - implementação java inclusa no JRE
- wolfSSL (antigo CyaSSL)
- muitas outras:
  - ver, por exemplo: http://en.wikipedia.org/wiki/Comparison_of_TLS_implementations

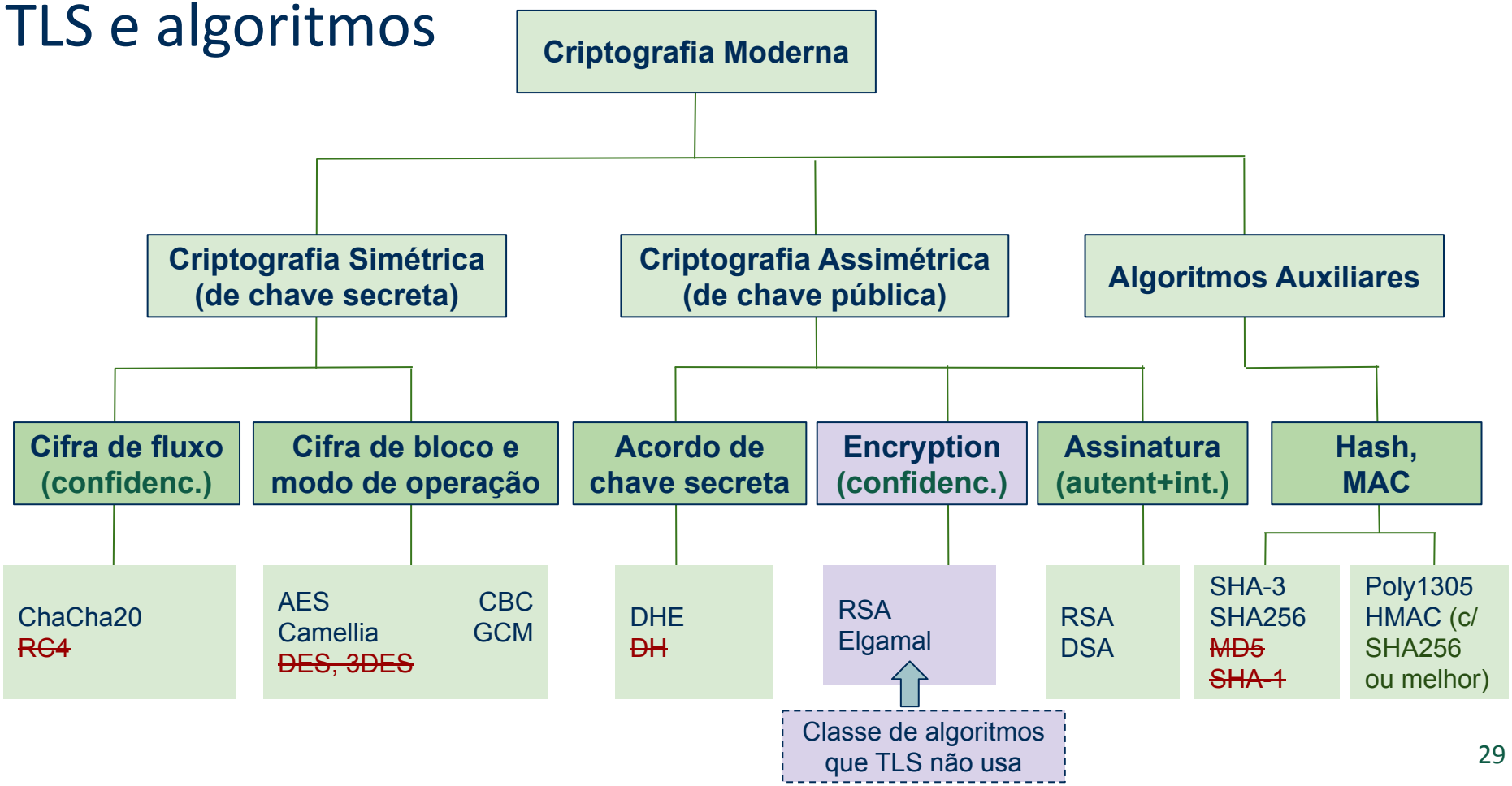
Importante: Manutenção TLS/SSL

SSL and TLS protocols

Protocol	Published	Status
SSL 1.0	Unpublished	Unpublished
SSL 2.0	1995	Deprecated in 2011 (RFC 6176)
SSL 3.0	1996	Deprecated in 2015 (RFC 7568)
TLS 1.0	1999	Deprecated in 2021 (RFC 8996)[20][21][22]
TLS 1.1	2006	Deprecated in 2021 (RFC 8996)[20][21][22]
TLS 1.2	2008	In use since 2008[23][24]
TLS 1.3	2018	In use since 2018[24][25]

Fonte: https://en.wikipedia.org/wiki/Transport_Layer_Security

TLS e algoritmos



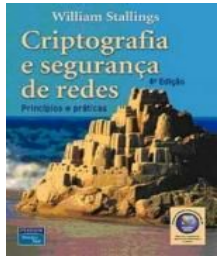
Próximas Aulas

- quinta-feira:
  - Laboratório com criptografia assimétrica
- Na outra semana:
  - Programação segura

Estudo Individual

Leituras Sugeridas

- Stallings, W. Criptografia e segurança de redes – Princípios e Práticas, 4 edição, ed Prentice Hall, 2008.



- Goodrich, Tamassia. Introdução à Segurança de Computadores. Bookman, 2013.

Questões de Autoavaliação

(não precisa entregar)

Exercício

Considere um serviço Web de Internet Banking sob TLS.

a) Cite que serviços de segurança são desejáveis (confidencialidade, integridade, autenticidade e disponibilidade) e justifique.

b) Cite exemplos de algoritmos que são usados para cada um dos serviços acima. Explique se são algoritmos de chave simétrica, assimétrica ou auxiliares (considere todas as etapas do TLS e procure lembrar de todos algoritmos já vistos).